

- Professional development programs to be in place for the institution's audit staff to maintain the necessary technical expertise.

All institutions are encouraged to implement risk-based IT audit procedures based on a formal risk assessment methodology to determine the appropriate frequency and extent of work. See the "Risk Assessment and Risk-Based Auditing" section of this booklet for more detail.

IT audit procedures will vary depending upon the philosophy and technical expertise of the audit department and the sophistication of the data center and end-user systems. However, to achieve effective coverage, the audit program and expertise of the staff must be consistent with the complexity of data processing activities reviewed. The audit procedures may include manual testing processes or computer-assisted audit programs (discussed later in this section).

The audit department should establish standards for audit work papers, related communications, and retention policies. Auditors should ensure that work papers are well organized, clearly written, and address all areas in the scope of the audit. They should contain sufficient evidence of the tasks performed and support the conclusions reached. Formal procedures should exist to ensure that management and the audit committee receive summarized audit findings that effectively communicate the results of the audit. Full audit reports should be available for review by the audit committee. Policies should establish appropriate work paper retention periods. Institutions should consider conducting their internal audit activities in accordance with professional standards, such as the Standards for the Professional Practice of Internal Auditing issued by the Institute for Internal Auditors (IIA), and those issued by the Standards Board of the Information Systems Audit and Control Association (ISACA). These standards address independence, professional proficiency, scope of work, performance of audit work, management of internal audit, and quality assurance reviews.

IT auditors frequently use computer-assisted audit techniques (CAATs) to improve audit coverage by reducing the cost of testing and sampling procedures that otherwise would be performed manually. CAATs include many types of tools and techniques, such as generalized audit software, utility software, test data, application software tracing and mapping, and audit expert systems. CAATs may be:

- Developed by internal programming staff or by outside programmers with audit department supervision;
- Purchased generalized audit software, e.g., audit packages offered by CPA firms or software vendors;
- Developed by IT auditors; or
- Acquired from equipment manufacturers and software houses to analyze machine, programmer, and operations efficiency.

Whatever the source, audit software programs should remain under the strict control of the audit department. For this reason, all documentation, test material, source listings,

source and object program modules, and all changes to such programs, should be strictly controlled. In installations using advanced software library control systems, audit object programs may be catalogued with password protection. This is acceptable if the auditors retain control over the documentation and the appropriate job control instructions necessary to retrieve and execute the object program from the libraries where it is stored. If internal control procedures within the computer system do not allow for strict audit control, audit programs should not be catalogued. Computer programs intended for audit use should be documented carefully to define their purpose and to ensure their continued usefulness and reliability.

CAATs may be used in performing various audit procedures, including the following:

- Tests of transactions and balances, such as recalculating interest;
- Analytical review procedures, such as identifying inconsistencies or significant fluctuations;
- Compliance tests of general controls, such as testing the set-up or configuration of the operating system or access procedures to the program libraries;
- Sampling programs to extract data for audit testing;
- Compliance tests of application controls such as testing the functioning of a programmed control;
- Recalculating entries performed by the entity's accounting systems; and
- Penetration testing.

These tools and techniques can also be used effectively to check data integrity by testing the logical processing of data "through" the system, rather than by relying only on validations of input and output controls.

Risk Assessment and Risk-Based Auditing

Action Summary

The board of directors should establish an effective risk-based audit function.

An effective risk-based auditing program will cover all of an institution's major activities. The frequency and depth of each area's audit will vary according to the risk assessment of that area. Examiners should determine whether the audit function is appropriate for the size and complexity of the institution.

Program Elements

Properly designed risk-based audit programs increase audit efficiency and effectiveness. The sophistication and formality of risk-based audits may vary depending on the institution's size and complexity. To determine the appropriate level of audit coverage for the organization's IT environment, management should define an effective risk assessment methodology. This assessment methodology should provide the auditor and the board with objective information to prioritize the allocation of audit resources properly. Risk-based IT audit programs should:

- Identify the institution's data, application and operating systems, technology, facilities, and personnel;
- Identify the business activities and processes within each of those categories;
- Include profiles of significant business units, departments, and product lines, or systems, and their associated business risks and control features, resulting in a document describing the structure of risk and controls throughout the institution;
- Use a measurement or scoring system that ranks and evaluates business and control risks for significant business units, departments, and products;
- Include board or audit committee approval of risk assessments and annual risk-based audit plans that establish audit schedules, audit cycles, work program scope, and resource allocation for each area audited;
- Implement the audit plan through planning, execution, reporting, and follow-up; and
- Include a process that regularly monitors the risk assessment and updates it at least annually for all significant business units, departments, and products or systems.

Risk Scoring System

A successful risk-based IT audit program can be based on an effective scoring system. ^[7] In establishing a scoring system, the board of directors and management should ensure the system is understandable, considers all relevant risk factors, and, to the extent possible, avoids subjectivity. Major risk factors commonly used in scoring systems include the following:

- The adequacy of internal controls;
- The nature of transactions (for example, the number and dollar volumes and the complexity);
- The age of the system or application;
- The nature of the operating environment (for example, changes in volume, degree of system and reporting centralization, sensitivity of resident or processed data, the

impact on critical business processes, potential financial impact, planned conversions, and economic and regulatory environment);

- The physical and logical security of information, equipment, and premises;
- The adequacy of operating management oversight and monitoring;
- Previous regulatory and audit results and management's responsiveness in addressing issues;
- Human resources, including the experience of management and staff, turnover, technical competence, management's succession plan, and the degree of delegation; and
- Senior management oversight.

Auditors should develop written guidelines on the use of risk assessment tools and risk factors and review these guidelines with the audit committee or the board of directors. The sophistication and formality of guidelines will vary for individual institutions depending on their size, complexity, scope of activities, geographic diversity, and various technologies used. The institution can rely on standard industry practice or on its own experiences to define risk scoring. Auditors should use the guidelines to grade or assess major risk areas and to define the range of scores or assessments (e.g., groupings such as low, medium, and high risk or a numerical sequence such as 1 through 5).

The written risk assessment guidelines should specify the following elements:

- A maximum length for audit cycles based on the risk scores. (For example, some institutions set audit cycles at 12 months or less for high-risk areas, 24 months or less for medium-risk areas, and up to 36 months for low-risk areas. Audit cycles should not be open-ended.);
- The timing of risk assessments for each department or activity. (Normally risks are assessed annually, but more frequent assessments may be needed if the institution experiences rapid growth or significant change in operation or activities.);
- Documentation requirements to support scoring decisions; and
- Guidelines for overriding risk assessments in special cases and the circumstances under which they can be overridden. (For example, the guidelines should define who can override assessments, and how the override is approved, reported and documented.)

Numerous industry groups offer resources where institutions can obtain matrices, models, or additional information on risk assessments. Among these groups are: ISACA, American Bankers Association (ABA), American Institute of Certified Public Accountants (AICPA), and IIA. Day-to-day management of the risk-based audit program rests with the internal audit manager, who monitors the audit scope and risk assessments to ensure that audit coverage remains adequate. The internal audit manager also prepares reports showing the risk rating, planned scope, and audit cycle for each area. The audit manager

should confirm the risk assessment system's reliability at least annually or whenever significant changes occur within a department or function. Operating department managers and auditors should work together in evaluating the risk in all departments and functions by reviewing risk assessments to determine their reasonableness.

Auditors should periodically review the results of internal control processes and analyze financial or operational data for any impact on a risk assessment or scoring. Accordingly, operating management should be required to keep auditors up to date on all major changes in departments or functions, such as the introduction of a new product, implementation of a new system, application conversions, or significant changes in organization or staff.

Audit Participation in Application Development, Acquisition, Conversions, and Testing

Action Summary

Senior management should involve IT audit in major application development, acquisition, conversion, and testing.

The development, acquisition, or conversion of an automated application is a lengthy and complex process requiring a significant degree of interaction among the programming staff, user departments, and internal audit. This process, known as the system development life cycle or system development methodology, requires detailed developmental stages to ensure that applications meet the needs of the institution. As each stage of the life cycle is reached, the auditor should review the internal controls, testing, and audit trails included in the application. The incorporation of internal controls within a completed application already in production is usually more difficult and expensive. Guidelines should be developed to facilitate the review of new applications during the design phase so that controls can be identified during independent audit review early in the development process.

The institution's audit policy, as approved by the board of directors, should include guidelines detailing what involvement internal audit will have in the development, acquisition, conversion, and testing of major applications. This includes describing the monitoring, reporting, and escalation processes (when internal controls are found to be insufficient or when testing is found to be inadequate). For acquisitions, this includes describing the phases of the system development life cycle in which IT audit will be involved. For acquisitions with significant IT impacts, participation of IT audit may be necessary early in the due diligence stage.

It is necessary that audit's participation in the development process be independent and objective. Auditors can determine and should recommend appropriate controls to project management. However, such recommendations do not necessarily "pre-approve" the controls, but instead guide the developers in considering appropriate control standards and structures throughout their project. The auditors are more than just "consultants" on internal controls. While they should not have any direct involvement in management decisions, they should raise objections if they believe the control environment to be

inadequate.

Once a new application system, conversion, or major revision to an existing system is accepted for production processing, the IT auditor should conduct a post-implementation review. This review should occur shortly after the implementation of the new or revised system and should include extensive testing of program logic, calculations, error conditions, edits, and controls. Such testing helps to validate that the software operates as expected. By performing the review soon after migration to the production environment, the auditors can quickly identify processing errors or other unsatisfactory conditions. A prompt post-implementation review should minimize potential losses from processing errors or ineffective software operation or controls and loss of reputation caused by inaccurate information provided to customers.

In larger IT facilities, formal quality assurance or change management groups may have primary responsibility for post-implementation reviews. In such cases, the IT auditor may choose not to perform a separate review but instead to participate in establishing the test criteria and evaluating results of any other independent reviews.

Outsourcing Internal IT Audit

Action Summary

The board of directors of an institution that outsources its internal IT audit function should ensure that the structure, scope, and management of the outsourcing arrangement provides for an adequate evaluation of the system of internal controls.

In addressing quality and resource issues, many institutions engage independent public accounting firms and other outside professionals to perform work that has been traditionally carried out by internal auditors. These arrangements are often called "internal audit outsourcing," "internal audit assistance," "audit co-sourcing," or "extended audit services."

Outsourcing such audit services may be beneficial to an institution if it is properly structured, carefully conducted, and prudently managed. To do this, management should ensure that there are no conflicts of interest and that the use of these services does not compromise independence. Potential conflicts of interest may arise if the outsourced auditing firm performs IT audit functions in addition to other audit services, such as providing the independent financial statement, or serving in an IT or management consulting capacity. The board of directors of an institution remains responsible for ensuring that the outsourced internal audit function operates effectively and complies with all regulations governing such arrangements.

Examiners should assess whether the structure, scope, and management of an internal audit outsourcing arrangement adequately evaluate the institution's system of internal controls. They should also determine whether or not directors and senior managers have fulfilled their responsibilities for maintaining an effective system of internal controls and for overseeing the internal audit function in an outsourced internal audit environment.

Additional detailed guidance on the structure, independence, and sound practices

concerning the use of outsourcing audit providers is available in the "Interagency Policy Statement on the Internal Audit Function and Its Outsourcing."

Independence of the External Auditor Providing Internal Audit Services

It is important that examiners ensure that management has designed any outsourcing arrangements in order to maintain the independence of the audit provider. An accounting firm hired to perform internal audit services for an institution risks compromising its independence when it also performs the external audit for the institution. Concerns arise because, rather than having an independent review, the responsibility of performing outsourced internal audits places the accounting firm in the position of auditing its own work. For example, in designing procedures to audit an institution's financial statements, the accounting firm considers the extent to which it may rely on the institution's internal control system, including the internal audit function.

The Sarbanes-Oxley Act of 2002 specifically prohibits a registered public accounting firm from performing certain non-audit services for a public company client for whom it performs financial statement audits. Among those prohibited non-audit services are internal audit outsourcing services and financial information system design and implementation. Under rules adopted by the Securities and Exchange Commission, this prohibition generally became effective on May 6, 2003, although a one-year transition period was provided for contractual arrangements in place as of that date. Under Section 36 of the Federal Deposit Insurance Act and its implementing regulation and guidelines, FDIC-insured depository institutions with total assets of \$500 million or more are required to be audited annually. The guidelines require these institutions, whether or not they are public companies, and their external auditors to comply with the SEC's auditor independence requirements. Other non-public institutions are encouraged to have their financial statements audited and to follow the Sarbanes-Oxley Act's prohibition on outsourcing internal audit to their external auditor. However, there are circumstances in which these institutions can use the same accounting firm for both external and internal audit work.

Examples of Arrangements

An outsourcing arrangement is a contract between the institution and an audit services firm to provide internal audit services. Outsourcing arrangements take many forms and are used by institutions of all sizes. The services under contract can be as limited as assisting internal audit staff with an assignment in which they lack expertise. This type of arrangement would typically fall under the control of the institution's internal audit manager, to whom the audit provider would typically report.

Other outsourcing arrangements may call for an audit provider to perform all or several parts of the internal audit work. Under these types of arrangements, the institution should maintain an internal audit manager and, as appropriate, internal audit staff sufficient to oversee vendor activities. The audit provider usually assists the internal audit function in determining the institution's areas of risk and the levels of risk to be reviewed, and recommends and performs audit procedures approved by the institution's internal audit manager. In addition, the outsourced audit provider should work jointly with the internal audit manager in reporting significant findings to the board or its audit committee.

Before entering into an outsourcing arrangement, the institution should perform due diligence to ensure that the audit provider has a sufficient number of qualified staff members to perform the contracted work. Because the outsourcing arrangement is a professional or personnel services contract, the institution's internal audit manager should have confidence in the competence of the staff assigned by the audit provider and receive timely notice from the vendor of any key staffing changes. Throughout the outsourcing arrangement, management should ensure that the audit provider maintains sufficient expertise to perform effectively and fulfill its contractual obligations.

When an institution enters into an outsourcing arrangement, or significantly changes the mix of internal and external resources used by internal audit, operational risk may increase. Because the arrangement could be terminated suddenly, the institution should have a contingency plan to mitigate any significant gap in audit coverage, particularly for high-risk areas. In its planning, an institution should consider possible alternatives and determine what it will do if an auditor with specialized knowledge or skills is unable to complete reviews of high risk areas, or if an outsourcing arrangement is terminated. For example, management could maintain information about the services offered and areas of expertise, as well as contact names and phone numbers, of other firms in their geographic area that could provide internal audit assistance in specific areas or a broader range of outsourcing services.

When negotiating the outsourcing arrangement with a vendor, an institution should carefully consider its current and anticipated business risks in setting each party's internal audit responsibilities. To clearly define the institution's duties and those of the outsourcing vendor, the institution should have a written contract, often referred to as an engagement letter.^[8] The contract should:

- Define the expectations and responsibilities for both parties;
- Set the scope, frequency, and cost of work to be performed by the vendor;
- Set responsibilities for providing and receiving information, such as the manner and frequency of reporting to senior management and the board about the status of contract work;
- Establish the protocol for changing the terms of the service contract, especially for expansion of audit work if significant issues are found, and stipulations for default and termination of the contract;
- State that any information pertaining to the institution must be kept confidential;
- Specify the locations of internal audit reports and the related work papers;
- Specify the period of time that vendors must maintain the work papers;^[9]
- State that outsourced internal audit services provided by the vendor are subject to regulatory review and that examiners will be granted full and timely access to the internal audit reports and related work papers prepared by the outsourcing vendor;^[10]
- State that internal audit reports are the property of the institution, that the institution will be provided with any copies of the related work papers it deems necessary, and that employees authorized by the institution will have reasonable and timely access

to the work papers prepared by the audit provider;

- Prescribe a process (arbitration, mediation, or other means) for resolving problems and for determining who bears the cost of consequential damages arising from errors, omissions, and negligence; and
- State that audit providers will not perform management functions, make management decisions, or act or appear to act in a capacity equivalent to that of an employee or a member of management of the institution, and will comply with professional and regulatory independence guidance.

Directors and senior management should ensure that the outsourced internal audit function is competently managed. For example, larger institutions should employ sufficient competent staff members in the internal audit department to assist the internal audit manager in overseeing the outsourcing vendor. Smaller institutions that do not employ a full-time audit manager should appoint a competent institution employee to oversee the outsourcing vendor's performance under the contract. This person should report directly to the audit committee for purposes of communicating audit issues and ideally should have no managerial responsibility for the area being audited.

Communication among the internal audit function, the audit committee, and senior management should not diminish because the institution engages an outsourcing vendor. The institution's audit manager should be involved with the audit provider in defining the audit universe and setting a risk-based IT audit schedule. The audit provider should appropriately document all work and promptly report all control weaknesses found during the audit to the institution's internal audit manager.

The outsourcing vendor should work with the internal audit manager to mutually determine what audit findings are significant and should be emphasized when reported to the board and its audit committee. The concept of materiality as the term is used in financial statement audits is not necessarily a good indicator of which control weaknesses to report. For example, reportable weaknesses could affect the institution's reputation or compliance with laws and regulations without a direct impact on the financial statements.

Third-Party Reviews of Technology Service Providers

A technology service provider (TSP) that processes work for financial institutions often is subject to separate audits by internal auditors from each of the serviced institutions. These audits may duplicate each other, creating a hardship on the provider's management and resources. The TSP can reduce that burden by arranging for its own third-party audit to determine the status and reliability of internal controls and by sharing the results of that audit with its client financial institutions.

A third-party audit or review is performed by independent auditors who are not employees of either the TSP or the serviced institution(s). The TSP, its auditors, or its serviced institutions may engage the third-party auditor. The serviced institutions' auditors may use this third-party review to determine the scope of any additional audit coverage they require to evaluate the system and controls at the TSP. Examiners can

also use the third-party review to help scope their supervisory activities.

Financial institutions are required to effectively manage their relationships with key TSPs. Institution management meets this requirement related to audit controls by:

- Directly auditing the TSP's operations and controls
- Employing the services of external auditors to evaluate the TSP's operations and controls; or
- Receiving from, and reviewing sufficiently detailed independent audit reports on, the TSP.

Financial institutions using such audits to complement their own coverage should ensure that the independent auditor is qualified to perform the review, that the scope satisfies their own audit objectives, and that any significant deficiencies reported are corrected. It is critically important that the examiner and the institution understand the nature and scope of the engagement and the level of assurance accruing from the work product of the reviewing firm.

There are two common types of independent third-party reviews: attestation reviews and non-attestation reviews. Attestation reviews ^[11] are generally conducted by Certified Public Accountants (CPAs) and are based upon Attestation Standards issued by the American Institute of Certified Public Accounts (AICPA). Non-attestation reviews include those performed by IT consultants or others; they may be based upon external standards ^[12] or industry developed criteria. ^[13]

The type of independent third-party review chosen should be based upon the size and complexity of the servicer, the products and services it offers, and its risk profile because the level of assurance provided varies with each type of review.

Users of audit reports or reviews should not rely solely on the information contained in the report to verify the internal control environment of the TSP. They should use additional verification and monitoring procedures as discussed more fully in the Outsourcing Technology Services Booklet of the FFIEC IT Examination Handbook. Refer to that booklet for additional information on vendor management and to supplement the examination coverage in this booklet.